

Category	SOC 2	ISO 27001	Regulatory Compliance
Type	Trust / assurance framework (customer-driven)	Information Security Management System (certifiable standard)	Laws and government regulations
Who sets it	Customer expectations via AICPA Trust Services Criteria	International Standards Organization (ISO)	Governments / regulators
Why it exists	Prove to customers that controls are in place and operating consistently	Create a structured, auditable security program with continuous improvement	Enforce legal minimum requirements for security, privacy, or industry safety
Is it mandatory?	No (but often required by customers)	No (but often required for enterprise trust)	Yes (if applicable to jurisdiction or industry)
Output	Audit report (SOC 2 Type I or Type II)	Certificate of compliance + audit report	Legal compliance status (no single "report" format)
Focus area	Controls + evidence over time	Management system + risk treatment + controls	Law-specific requirements (privacy, financial, healthcare, etc.)
Example requirement	MFA enabled, access logging, incident tracking	Risk assessment process, internal audit cycle, control framework	Data breach notification laws, financial reporting rules, patient data protection rules
Time nature	Point-in-time + operating period review	Continuous system with periodic audits	Ongoing legal obligation
Enforcement consequence	Loss of customers, failed audits	Loss of certification, reputational impact	Fines, lawsuits, regulatory penalties
Typical use case	SaaS company selling to enterprises	Organization building formal security governance	Any company operating under legal jurisdiction requirements